Киберқауіпсіздік негіздері

EduLibrary Demo Content

Қауіп моделін құру, есептік жазбаны қорғау, қауіпсіз файлдар, енгізуді тексеру және оқиғаға жауап беру туралы қорғанысқа бағытталған түпнұсқа сабақтар.

Қысқаша сабақтар · 2026 · Қазақша

Оқу жолы

Бұл материалды қалай оқу керек

Әр сабақтағы ұғымды оқып, мысалды қолмен жүргізіңіз. Содан кейін тәжірибе тапсырмасын өзіңіз орындап, соңғы беттегі түсіндірмемен салыстырыңыз. Код үзінділері оқу үшін ықшамдалған; олар толық өндірістік жүйені алмастырмайды.

1. Қауіп моделі және құндылық

2. Есептік жазбаны қорғау

3. Енгізу және шығару қауіпсіздігі

4. Файл жүктеу шекарасы

5. Бақылау және қалпына келу

Шағын жоба және жауаптарды тексеру

Авторлық құқық және шығу тегі

Автор: EduLibrary Demo Content. 2026 жылы EduLibrary демонстрациясы үшін жаңадан жазылған түпнұсқа қазақша сабақтар. Коммерциялық кітаптан көшірілген мәтін, тарау не файл қолданылған жоқ. Бұл материал бес дербес шағын оқу құралының бірі.

Лицензия: Creative Commons Attribution 4.0 International (CC BY 4.0). Авторды және осы лицензияны көрсетіп пайдалануға болады. Лицензия: https://creativecommons.org/licenses/by/4.0/ . Бастапқы мәтін мен генератор осы жобаның Data/DigitalDemo/content.json және tools/generate_digital_demo.py файлдарында сақталған.

1. Қауіп моделі және құндылық

Қауіпсіздік жұмысы нені қорғайтынымызды анықтаудан басталады. Университет кітапханасында оқырманның жеке дерегі, оқу тарихы, қызметкер рұқсаты және кітап қоры маңызды. Құпиялылық деректі рұқсатсыз оқудан, тұтастық рұқсатсыз өзгертуден, қолжетімділік қызметтің тоқтауынан қорғайды.

Қауіп моделінде дерек қайдан келетінін, қайда сақталатынын және сенім шекараларын белгілеңіз. Браузер, сервер және деректер қоры бірдей сенімді орта емес. Әр шекарада кім әрекет етіп жатқанын және неге рұқсаты барын тексеріңіз. Қауіптің ықтималдығы мен әсерін бірге бағалап, ең маңызды қорғаныстан бастаңыз.

Мысалды талдау

Asset: private reading history
Actor: signed-in reader
Boundary: browser -> server
Rule: reader sees only own history
Control: query scoped by authenticated UserId

Өзіңіз орындаңыз

Кітапты іздеу тарихы мен жалпы жария кітап атауының құпиялылық талабы бірдей ме? Қайсысына жеке қатынау тексеруі қажет?

2. Есептік жазбаны қорғау

Аутентификация пайдаланушының кім екенін, авторизация қандай әрекет жасай алатынын анықтайды. Жүйеге кіру барлық жазбаны көруге рұқсат бермейді. Әкімші мен студент рөлдерінің шекарасын нақты белгілеп, ең аз қажетті рұқсат қағидасын қолданыңыз.

Құпиясөздерді жай мәтінмен сақтамаңыз. Арнайы пароль хештеу құралы кездейсоқ тұз және есептеу құнын қолданады. Пайдаланушыға ұзын, бірегей құпиясөз және мүмкін болса көп факторлы тексеру ұсыныңыз. Кіру әрекетін шектеу автоматты болжауды баяулатады. Құпиясөзді, токенді немесе алып кету кодын журналға жазбаңыз.

Мысалды талдау

Authentication: Who is making the request?
Authorization: May this user change this record?
Ownership: Does this record belong to this user?
Audit: What happened, without logging secrets?

Өзіңіз орындаңыз

Студент URL ішіндегі Id мәнін өзгертіп, басқа адамның айыппұлын көруге тырысты. Тек [Authorize] атрибуты неге жеткіліксіз?

3. Енгізу және шығару қауіпсіздігі

Сенімсіз енгізу форма, файл, URL немесе API арқылы келеді. Тек рұқсат етілетін пішім мен шекараны қабылдау - пайдалы тәсіл. SQL сұрауына мәтінді біріктірудің орнына параметр қолданыңыз. Мәтіннің жарамдылығын тексеру оны барлық контексте қауіпсіз етеді дегенді білдірмейді.

HTML шығару кезінде кодтау мәтінді белгілеу тілі ретінде орындалудан сақтайды. Қауіпсіздік контекстке тәуелді: HTML мәтіні, атрибут, URL және JavaScript әртүрлі ереже талап етеді. Қарапайым мәтінді textContent арқылы көрсетіңіз. Сыртқы URL рұқсат етілсе, схемасын шектеңіз; javascript: сияқты орындалатын схеманы қабылдамаңыз.

Мысалды талдау

```
// Data remains a SQL parameter, not executable SQL.
query.Where(book => book.Title.Contains(search));

// Browser treats the value as text.
message.textContent = userProvidedTitle;
```

Өзіңіз орындаңыз

Қауіпсіз мәтіндік атауды innerHTML орнына textContent арқылы көрсету қандай қауіптің алдын алады? Бұл сервер тексеруін алмастыра ма?

4. Файл жүктеу шекарасы

Файл атауы мен MIME тақырыбы пайдаланушының бақылауында болады. Сондықтан кеңейтімді ғана тексеру жеткіліксіз. Қолдайтын пішімді, сигнатураны, көлемді және құрылымды тексеріңіз. Суретті сенімді декодермен ашып, қайта кодтау қауіпті метадеректі азайтады. Шектен тыс өлшем жадқа күш түсіруі мүмкін.

Сақтау атауын кездейсоқ сервер жасасын. Пайдаланушы атауын storage path ретінде қолданбаңыз. Қорғалған файлдар жалпы public каталогта тұрмасын; оларды рұқсат тексеретін endpoint арқылы беріңіз. EPUB - ZIP пакет, сондықтан сыртқы сілтеме, script және архивті ашқанда шектен тыс ұлғаю сияқты қауіптерді де бағалау қажет.

Мысалды талдау

Upload checks:
- Allowed format and detected signature
- Configured byte and expansion limits
- Safe parser / reconstruction
- Random storage name
- Authorized read endpoint

Өзіңіз орындаңыз

../../settings.json атауымен келген файлды сол атаумен сақтау қандай қатеге әкелуі мүмкін? Сервер қандай атау беруі керек?

5. Бақылау және қалпына келу

Қорғаныс тек қатені болдырмау емес, оны байқау және салдарын шектеу де. Маңызды әрекеттің уақыты, түрі және жауапты пайдаланушысы аудитке көмектеседі. Бірақ журналға құпия токен, пароль және артық жеке дерек түспесін. Қате хабарламасы пайдаланушыға түсінікті, ал техникалық егжей-тегжей рұқсат етілген ортада болсын.

Сақтық көшірменің бар болуы жеткіліксіз: қалпына келтіруді оқшауланған ортада тексеру керек. Оқиға кезінде деректі өшіріп жіберуге асықпай, әсер еткен рұқсатты шектеп, айғақты сақтап, жауапты адамға хабарлаңыз. Тәуелділіктерді жаңартып, тесттерді қайталау қауіпсіздіктің тұрақты бөлігі болады.

Мысалды талдау

Incident checklist:
1. Contain affected access
2. Preserve relevant evidence
3. Identify scope and impact
4. Restore from verified state
5. Fix cause and review controls

Өзіңіз орындаңыз

Пароль журналға жазылып кеткені анықталса, тек сол жолды өшіру неге жеткіліксіз? Қандай келесі әрекеттер қажет?

Жоба және өзіндік тексеру

Жеке оқу күнделігі үшін қорғаныс жоспарын жасаңыз: дерек ағыны, рөлдер, иелік тексеруі, қауіпсіз файл шекарасы және құпиясыз аудит. Үш ықтимал қателікті атаңыз және әрқайсысына алдын алу мен тексеру тәсілін ұсыныңыз. Тәжірибелерді тек өзіңізге тиесілі не арнайы рұқсат етілген ортада орындаңыз.

Тапсырмаларға түсіндірме

1. Жария атауды барлығы көре алады, ал жеке іздеу не оқу тарихын тек иесі және нақты рұқсаты бар қызметкер көруі тиіс. Құндылық пен контекст қорғаныс деңгейін анықтайды.

2. [Authorize] жүйеге кіргенін тексереді, бірақ жазба иесін әрдайым тексермейді. Сұрау ағымдағы оқырманға тиесілі жазбамен шектелуі керек.

3. Мәтін HTML не script ретінде түсіндірілмейді, сондықтан енгізілген белгілеу орындалмайды. Бірақ рұқсат, ұзындық және домен ережелері серверде бәрібір тексеріледі.

4. Path traversal арқылы арналған каталогтан тыс жазуға талпыныс болуы мүмкін. Сервер кездейсоқ қауіпсіз файл атауын жасап, толық жолдың storage түбірінде қалуын тексеруі тиіс.

5. Көшірмелер не сыртқы журналдарда құпия қалған болуы мүмкін. Әсер еткен құпияны ауыстыру, қатынауды шектеу, таралу ауқымын анықтау және журналдау себебін түзету қажет.

Келесі қадам: жобаңызды басқа адамға түсіндіріп көріңіз. Қандай кіріс қабылданады, қандай ереже қорғалады және нәтижені қалай тексересіз?